

Vereinbarung zur Auftragsverarbeitung (AVV)

nach Art. 28 DSGVO

zwischen

dem im Registrierungs- bzw. Buchungsprozess angegebenen Unternehmen / Betrieb

– nachfolgend „**Auftraggeber**“ genannt –

und

CareTip UG (haftungsbeschränkt)

Kolonnenstraße 8, 10827 Berlin, Deutschland

– nachfolgend „**Auftragnehmer**“ genannt –

gemeinsam nachfolgend die „**Parteien**“ genannt.

Präambel

Diese Vereinbarung regelt die datenschutzrechtlichen Pflichten der Parteien im Rahmen der Nutzung der CareTip-Plattform. Die Vereinbarung kommt gemäß Art. 28 Abs. 9 DSGVO in elektronischer Form (Textform) durch die Bestätigung des Auftraggebers im Rahmen des Online-Registrierungs- oder Buchungsprozesses zustande.

1. Einleitung, Geltungsbereich, Definitionen

1.1. Dieser Vertrag regelt die Rechte und Pflichten der Parteien im Rahmen einer Verarbeitung von personenbezogenen Daten im Auftrag im Sinne des Art. 28 der EU-Datenschutzgrundverordnung (DSGVO).

1.2. Dieser Vertrag findet Anwendung auf alle Tätigkeiten im Rahmen des Hauptvertrags (Nutzungsvereinbarung / AGB zur CareTip-Plattform), bei denen der Auftragnehmer, seine Mitarbeiter oder durch ihn beauftragte Subunternehmer personenbezogene Daten des Auftraggebers verarbeiten.

1.3. In diesem Vertrag verwendete Begriffe entsprechen ihrer Definition in der DSGVO. Textform (z. B. E-Mail, Checkbox-Bestätigung) ist für Erklärungen ausreichend, sofern nichts anderes vereinbart ist.

2. Gegenstand und Dauer der Verarbeitung

2.1. Der Auftragnehmer übernimmt die Bereitstellung der CareTip-Softwareplattform zur digitalen Abwicklung, Zuordnung und Auswertung von Trinkgeldern und Gästefeedback.

2.2. Gegenstand, Art und Zweck der Verarbeitung sowie die Kategorien von Daten und Betroffenen ergeben sich aus dieser Vereinbarung sowie dem zugrundeliegenden Hauptvertrag.

2.3. Die Verarbeitung beginnt mit der Erstellung des Kundenkontos und erfolgt auf unbestimmte Zeit bis zur Beendigung des Hauptvertrags.

3. Art, Zweck und Umfang der Datenverarbeitung

3.1. Zweck der Verarbeitung:

Erfassung, Verwaltung, Zuordnung, Auswertung und Bereitstellung von digitalen Trinkgeldern, In-App-Benachrichtigungen, Auszahlungs-Umsätzen und Gästefeedback für den Betrieb des Auftraggebers.

3.2. Kategorien personenbezogener Daten:

- **Stammdaten & Kontaktdaten:** Name, E-Mail-Adresse, Telefonnummer,
- **Mitarbeiterdaten:** Profildaten, Identifikations-IDs, Abrechnungs- und Auszahlungsinformationen.
- **Gastdaten (flüchtig/optional):** Freiwillig abgegebenes Feedback, Bewertungsnoten, Transaktions-Metadaten.
- **Technische Daten:** IP-Adressen (anonymisiert/gekürzt), Session-Logs, QR-Scan-Metadaten.

(Hinweis: Besondere Kategorien personenbezogener Daten nach Art. 9 DSGVO, wie z. B. Gesundheitsdaten, werden ausdrücklich nicht verarbeitet).

3.3. Kategorien der Betroffenen:

- Mitarbeiter und Beschäftigte des Auftraggebers
- Kunden / Gäste des Auftraggebers (bei der Nutzung der Trinkgeldfunktion)

4. Pflichten des Auftragnehmers

4.1. Der Auftragnehmer verarbeitet personenbezogene Daten ausschließlich wie vertraglich vereinbart oder auf dokumentierte Weisung des Auftraggebers, es sei denn, er ist durch Unionsrecht oder das Recht der Mitgliedstaaten zur Verarbeitung verpflichtet.

4.2. Der Auftragnehmer sichert zu, dass die zur Verarbeitung befugten Personen zur Vertraulichkeit verpflichtet wurden oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen.

4.3. Der Auftragnehmer unterstützt den Auftraggeber unter Berücksichtigung der Art der Verarbeitung und der ihm zur Verfügung stehenden Informationen bei der Einhaltung der in den Artikeln 32 bis 36 DSGVO genannten Pflichten (Sicherheitsmaßnahmen, Meldungen von Datenpannen, Datenschutz-Folgenabschätzungen).

4.4. Die Verarbeitungen erfolgen grundsätzlich innerhalb der EU / des EWR. Eine Verarbeitung in Drittländern erfolgt nur bei Vorliegen der gesetzlichen Voraussetzungen der Art. 44 ff. DSGVO (z. B. auf Basis von Angemessenheitsbeschlüssen der EU-Kommission oder EU-Standardvertragsklauseln).

5. Technische und organisatorische Maßnahmen (TOMs)

5.1. Der Auftragnehmer richtet die in **Anlage 1** beschriebenen technischen und organisatorischen Maßnahmen ein und hält diese aufrecht.

5.2. Die Maßnahmen können der technischen Weiterentwicklung angepasst werden, solange das vereinbarte Sicherheitsniveau nicht unterschritten wird.

5.3. Mobiles Arbeiten / Homeoffice ist den Mitarbeitern des Auftragnehmers gestattet, sofern angemessene Sicherheitsvorkehrungen (z. B. verschlüsselte Verbindungen, Passwortschutz, aktuelle Betriebssysteme) eingehalten werden.

6. Unterauftragsverhältnisse (Subunternehmer)

6.1. Der Auftraggeber erteilt dem Auftragnehmer die allgemeine Genehmigung, Subunternehmer hinzuzuziehen. Die bei Vertragsschluss eingesetzten Subunternehmer sind in **Anlage 2** aufgeführt.

6.2. Der Auftragnehmer informiert den Auftraggeber im Voraus über jede beabsichtigte Änderung bezüglich der Hinzuziehung oder Ersetzung von Subunternehmern (z. B. per E-Mail oder In-App-Mitteilung). Der Auftraggeber kann innerhalb von 14 Tagen aus wichtigen datenschutzrechtlichen Gründen Widerspruch einlegen. Erfolgt kein Widerspruch, gilt die Änderung als genehmigt.

6.3. Geht der Subunternehmer Verarbeitungspflichten in einem Drittland ein, stellt der Auftragnehmer das Vorliegen angemessener Datenschutzgarantien (z. B. EU-US Data Privacy Framework) sicher.

7. Rechte des Auftraggebers und Kontrollrechte

7.1. Der Auftragnehmer stellt dem Auftraggeber auf Anfrage alle erforderlichen Informationen zum Nachweis der Einhaltung der Pflichten nach Art. 28 DSGVO zur Verfügung.

7.2. Der Nachweis der Einhaltung kann vorrangig durch die Vorlage aktueller Zertifikate, Berichte unabhängiger Instanzen oder Selbstauskünfte erbracht werden.

7.3. Vor-Ort-Kontrollen beim Auftragnehmer finden nach angemessener Vorankündigung (mindestens 14 Tage) zu gewöhnlichen Geschäftszeiten ohne Störung des Betriebsablaufs statt. Entstehen dem Auftragnehmer durch Vor-Ort-Audits erhebliche Aufwände, können diese dem Auftraggeber nach vorheriger Absprache zu angemessenen Stundensätzen berechnet werden, es sei denn, das Audit ist durch einen begründeten Verdacht eines Datenverstoßes veranlasst.

8. Mitteilungspflichten bei Datenpannen

8.1. Der Auftragnehmer teilt dem Auftraggeber Verletzungen des Schutzes personenbezogener Daten **unverzüglich** mit, nachdem er davon Kenntnis erlangt hat.

8.2. Die Mitteilung enthält die gesetzlich geforderten Mindestangaben zur Art der Verletzung, den betroffenen Kategorien sowie den ergriffenen Schutzmaßnahmen.

9. Beendigung des Auftrags und Datenlöschung

9.1. Nach Beendigung des Hauptvertrags wird der Auftragnehmer alle im Auftrag verarbeiteten Daten nach Wahl des Auftraggebers entweder löschen oder zurückgeben, sofern keine gesetzlichen Aufbewahrungspflichten (z. B. § 147 AO / § 257 HGB für steuerrelevante Transaktionsdaten) einer Löschung entgegenstehen.

9.2. Nach Ablauf von Kontrollöschungs- oder Aufbewahrungsfristen werden die Daten automatisiert gelöscht oder dauerhaft anonymisiert.

10. Haftung

Die Haftung richtet sich nach den Regelungen des Hauptvertrags sowie den gesetzlichen Bestimmungen der DSGVO (insbesondere Art. 82 DSGVO).

Anlage 1 – Technische und organisatorische Maßnahmen (TOMs)

Der Auftragnehmer gewährleistet ein angemessenes Schutzniveau nach Art. 32 DSGVO durch folgende Maßnahmen:

1. Vertraulichkeit (Art. 32 Abs. 1 lit. b DSGVO)

- **Zutrittskontrolle:** Zutritt zu Geschäftsräumen nur für berechtigte Personen; Verschließen von Räumen bei Abwesenheit; Alarmsicherungen.
- **Zugangskontrolle (Systeme):** Authentifizierung über individuelle Benutzerkonten; Nutzung von Zwei-Faktor-Authentifizierung (2FA) bei kritischen Systemen; Durchsetzung komplexer Passwort-Richtlinien.
- **Zugriffskontrolle (Daten):** Rollen- und Rechtekonzept auf Need-to-know-Basis; Mandantentrennung auf Datenbankebene (Isolation von Kundendaten).
- **Trennungsgebot:** Logische Trennung von Test-, Staging- und Produktionsumgebungen; Mandantenspezifische Datenverarbeitung.

2. Integrität (Art. 32 Abs. 1 lit. b DSGVO)

- **Weitergabekontrolle:** Verschlüsselung aller Datenübertragungen nach aktuellem Stand der Technik (TLS 1.2 / TLS 1.3 mit SSL-Zertifikaten); Verschlüsselung ruhender Daten (*Encryption at Rest*) bei Datenbank- und Cloud-Anbietern.
- **Eingabekontrolle:** Protokollierung von Systemzugriffen und administrativen Änderungen (Audit-Logs); Nachvollziehbarkeit von Datenänderungen.

3. Verfügbarkeit und Belastbarkeit (Art. 32 Abs. 1 lit. b DSGVO)

- **Verfügbarkeitskontrolle:** Nutzung hochverfügbarer Cloud-Infrastruktur mit redundanten Serverarchitekturen; Automatisierte tägliche Daten-Backups.
- **Wiederherstellbarkeit:** Reguläre Testläufe zur Einspielung von Backups (Disaster Recovery).

4. Verfahren zur regelmäßigen Überprüfung (Art. 32 Abs. 1 lit. d DSGVO)

- **Datenschutz-Management:** Regelmäßige Mitarbeiterschulungen und Verpflichtung aller Beschäftigten auf das Datengeheimnis; Kontinuierliche Überprüfung und Aktualisierung der Sicherheitsmaßnahmen.

Anlage 2 – Eingesetzte Subunternehmer

Der Auftraggeber genehmigt zum Zeitpunkt des Vertragsschlusses den Einsatz folgender Subunternehmer:

Subunternehmer / Dienstleister	Sitz	Gegenstand der Verarbeitung	Rechtsgrundlage / Drittland-Transfer
Stripe Payments Europe Ltd.	Irland / USA	Zahlungsabwicklung & Auszahlungen	EU-US Data Privacy Framework / EU-Standardvertragsklauseln (SCCs) / DPA
Render Services, Inc.	USA	Anwendungs-Hosting & API-Server	EU-US Data Privacy Framework / EU-Standardvertragsklauseln (SCCs) / DPA
Netlify, Inc.	USA	Frontend-Hosting & Web-Bereitstellung	EU-US Data Privacy Framework / EU-Standardvertragsklauseln (SCCs) / DPA
Plus Five Five, Inc. (Resend)	USA	Versand von System-E-Mails	EU-US Data Privacy Framework / EU-Standardvertragsklauseln (SCCs) / DPA
Google Ireland Limited	Irland / USA	Authentifizierung (Google Sign-In) & Analytics	EU-US Data Privacy Framework / EU-Standardvertragsklauseln (SCCs) / DPA

Anlage 3 – Weisungsberechtigte Personen und Inkrafttreten

1. Weisungserteilung und -entgegennahme:

- **Seitens des Auftraggebers:** Befugt sind die im Kundenkonto als Administrator hinterlegten Personen. Weisungen erfolgen primär über das Dashboard oder per E-Mail von der registrierten Inhaber-E-Mail-Adresse.
- **Seitens des Auftragnehmers:** Geschäftsführung der CareTip UG (haftungsbeschränkt). Anfragen und Weisungen können gerichtet werden an: info@caretip.de.

2. Wirksamkeit und Zustandekommen:

Dieser Vertrag tritt automatisch in Kraft, sobald der Auftraggeber die Vereinbarung zur Auftragsverarbeitung im Rahmen der Online-Registrierung oder Abo-Buchung durch das Setzen des Häkchens und den Abschluss der Buchung akzeptiert hat. Eine handschriftliche Unterzeichnung ist nicht erforderlich.